

Software Development Operations Policy

(Last Updated February 2026)

Purpose

The purpose of the Software Development Operations Policy is to establish consistent, secure, and controlled practices for managing the build, release, deployment, and operation of software applications. This policy defines requirements for application release management, source code governance, CI/CD pipelines, environment separation, and runtime protections to reduce the risk of unauthorized changes, insecure deployments, and operational failures. By enforcing standardized controls across development, staging, and production environments, this policy helps ensure that software changes are reviewed, tested, approved, traceable, and deployed in a manner that protects the confidentiality, integrity, and availability of organizational systems and data. The policy supports reliable software delivery, strengthens accountability throughout the release lifecycle, and enables the organization to meet business objectives, regulatory obligations, and cybersecurity governance expectations.

Scope

The Software Development Operations Policy applies to all software development activities conducted by employees, contractors, and third-party vendors on behalf of our organization. It encompasses the entire software development lifecycle, including planning, design, coding, testing, deployment, maintenance, and retirement of software applications and systems. This policy applies to all software development projects, regardless of the platform, programming language, or development methodology employed. It establishes guidelines, standards, and best practices to ensure the security, reliability, and integrity of the software developed within our organization. Compliance with this policy is mandatory for all individuals involved in software development, and adherence to industry-specific regulations, software licensing requirements, and intellectual property rights is essential. Deviations or exceptions to this policy must be approved by the designated authority responsible for software development governance and security.

Safeguards

To achieve the organization's overall mission, and the purpose of this cybersecurity policy, the organization shall:

- SDO-01 Maintain an application release management process to govern the design, review, testing, approval, and deployment of substantial changes to the applications maintained by software development teams.
- SDO-02 Ensure the organization's application release management process requires that change requests for applications maintained by software development teams include a checklist indicating that all required cybersecurity tasks have been completed.
- SDO-03 Ensure the organization's application release management process requires that changes to applications maintained by software development teams are reviewed by at least one developer other than the change's author.
- SDO-04 Ensure the organization's application release management process requires that a cybersecurity subject matter expert approves changes made to cybersecurity-focused modules in the applications maintained by software development teams (such as via CODEOWNERS).
- SDO-05 Ensure the organization's application release management process requires that cybersecurity checks are run in the deployment pipeline for applications maintained by software development teams.
- SDO-06 Ensure the organization's application release management process requires that cybersecurity checks are run in the development pipeline and pass those checks before applications maintained by software development teams are deployed to production.
- SDO-07 Ensure the organization's application release management process includes application programming interfaces (APIs) within the scope of design review, testing, approval, and deployment activities for applications maintained by software development teams.

- SDO-08 Ensure the organization's application release management process requires that secrets used by applications maintained by software development teams (such as API keys) are stored in an approved, secure vault.
- SDO-09 Ensure the organization's application release management process requires that the authentication secrets used by applications maintained by software development teams are rotated as required by the organization's authentication standards.
- SDO-10 Ensure the organization's application release management process requires that access to source code repositories and continuous integration / continuous deployment (CI/CD) platforms is restricted to authorized users and systems, in accordance with the organization's approved access control and identity management requirements.
- SDO-11 Ensure the organization's application release management process requires that source code repositories enforce branch protection and change control mechanisms to prevent unauthorized or unreviewed changes to protected branches.
- SDO-12 Ensure the organization's application release management process requires that build and deployment execution is restricted to authorized CI/CD runners and that approved software artifacts cannot be modified outside of the organization's defined release management process.
- SDO-13 Ensure the organization's application release management process requires that feature flags used by software development teams are reviewed, approved, and managed in accordance with the organization's security and deployment requirements.
- SDO-14 Ensure the organization's application release management process requires that all build, approval, and deployment events are logged to support traceability, auditing, and investigation of release activities.

- SDO-15 Ensure the organization's application release management process requires that all software artifacts generated by software development teams are cryptographically signed and verified before they are approved or deployed.
- SDO-16 Maintain an inventory of the platforms used in the organization's application release management process, including all development, staging, and production environments and the databases, services, and infrastructure components that support them.
- SDO-17 Maintain technical safeguards to enforce separation between the organization's development, staging, and production application platforms.
- SDO-18 Ensure the technical safeguards maintained to enforce separation between development, staging, and production application platforms restrict application developers' access to only the source code repositories and code management systems necessary to perform their development responsibilities.
- SDO-19 Ensure the technical safeguards maintained to enforce separation between development, staging, and production application platforms restrict application developers' access to only the application platforms and systems necessary for development and testing activities and prevent privileged access to production application platforms.
- SDO-20 Ensure the technical safeguards maintained to enforce separation between development, staging, and production application platforms restrict application developers' access to only the databases and data sets necessary for development and testing activities.
- SDO-21 Ensure the technical safeguards maintained to enforce separation between development, staging, and production application platforms prevent non-production application platforms from storing sensitive or personally identifiable information beyond what is necessary for testing and validation.

- SDO-22 Ensure the technical safeguards maintained to enforce separation between development, staging, and production application platforms prevent application programming interfaces (APIs) deployed in development and testing environments from exposing sensitive or production data beyond what is necessary for testing and validation purposes.
- SDO-23 Maintain runtime protections (such as Web Application Firewalls (WAFs) or Runtime Application Self-Protection (RASP) capabilities) for each of the organization's custom software applications that requires real-time protection, ensuring they are integrated into the application architecture and used to detect and block malicious runtime activity.
- SDO-24 Maintain Infrastructure as Code (IaC) capabilities to ensure that the organization's application platforms and environments can be deployed and rebuilt in a consistent and repeatable manner.

Policy Sanctions

Non-compliance with this policy may result in disciplinary action in line with our corporation's human resources procedures. Consequences may range from mandatory refresher training and written warnings to temporary suspension of remote access privileges and, in severe cases, termination of employment or contractual obligations. Individuals could be subject to legal consequences under applicable laws if violations involve illegal activities. These sanctions emphasize the critical importance of cybersecurity, the individual's role in protecting our digital assets, and the potential risks associated with policy violations. Enforcement will be consistent and impartial, with the severity of the action corresponding directly to the seriousness of the breach.